دانشگاه صنعتی شریف

دانشکده مهندسی کامپیوتر

گزارش تمرین و پیاده‌سازی تکلیف ۱

درس مدیریت و مهندسی امنیت اطلاعات

استاد درس: دکتر خرازی

دانشجو: فرهاد توکلیان

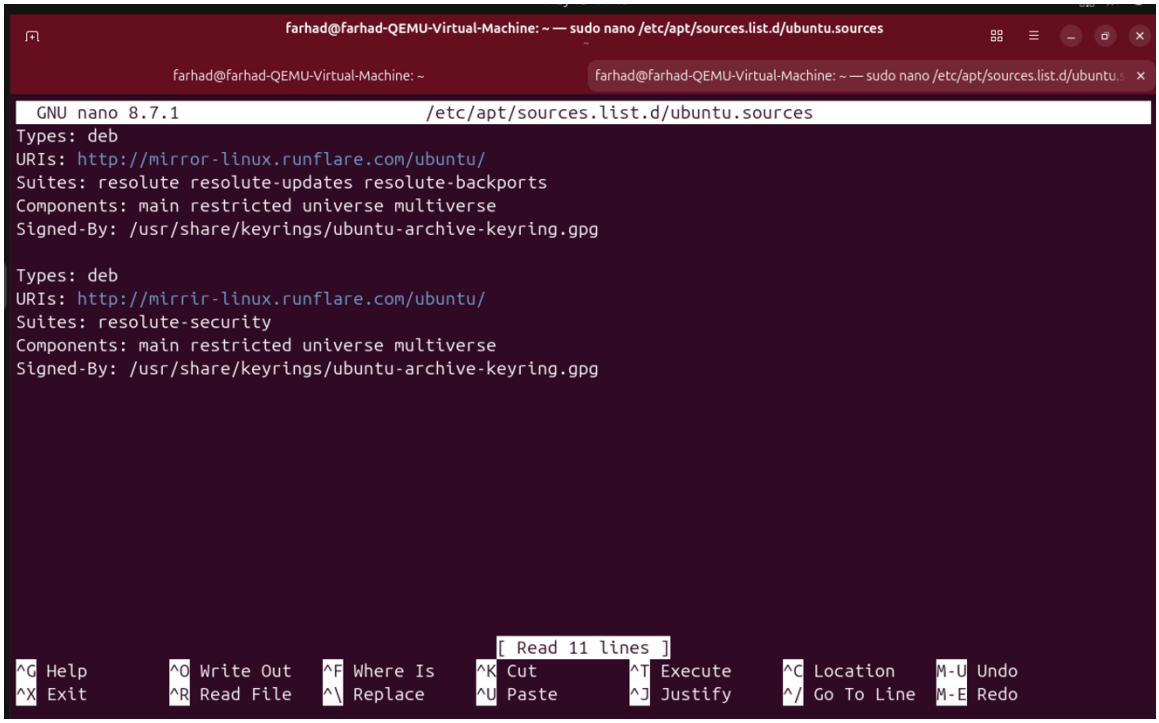
شماره دانشجویی: ۴۰۴۲۰۴۸۰۵

بهار ۱۴۰۵

آماده‌سازی محیط تمرین

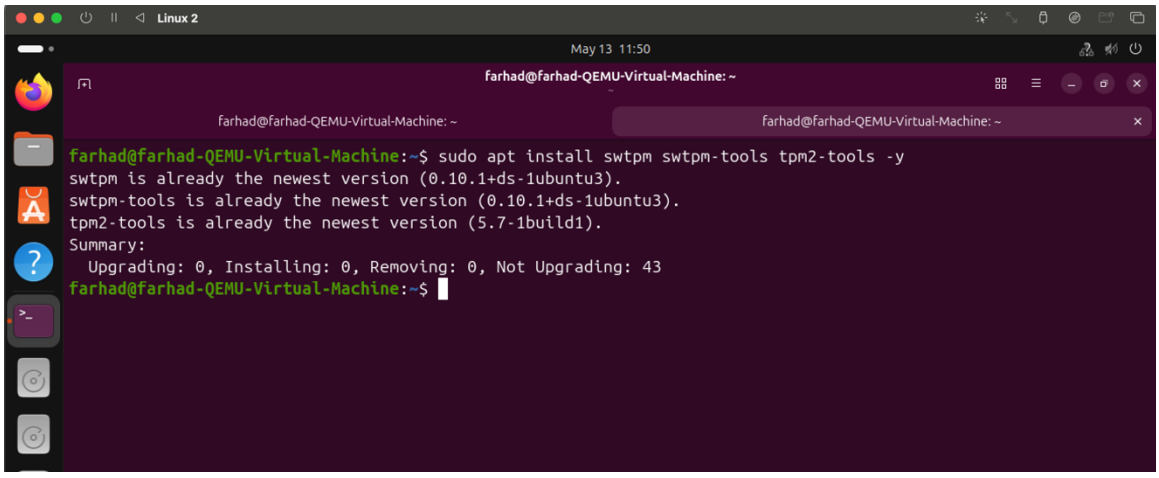
در ابتدا برای مجازی‌سازی از نرم‌افزار UTM استفاده و سیستم عامل Ubuntu-26-04 نصب شده است.

برای دانلود بسته‌های مورد نیاز از میرور runflare استفاده شده است.



عکس۱ – تنظیم میرور

نصب بسته‌های مورد نیاز راه‌اندازی TPM



عکس۲ - نصب بسته‌های مورد نیاز راه‌اندازی TPM

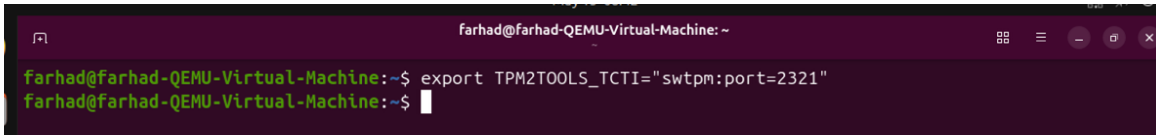
راه‌اندازی و تست TPM (بخش ۲.۱ تکلیف)

راه‌اندازی TPM روی پورت TCP 2321



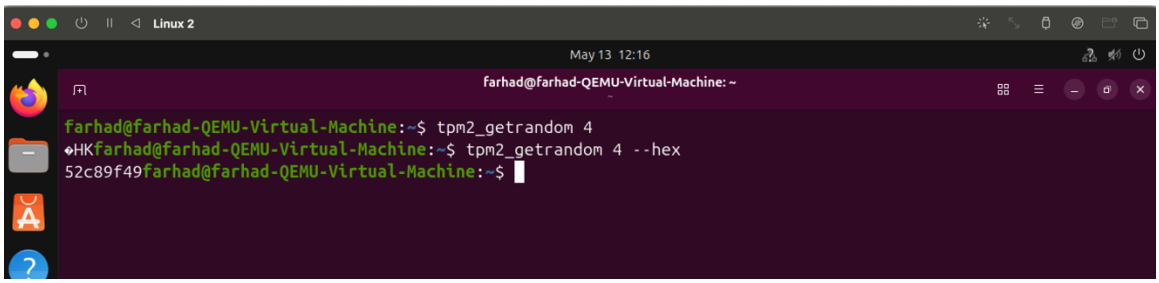
عکس۳ - راه‌اندازی TPM

تنظیم متغیر محلی



عکس۴ – اجرای کامند export TPM2TOOLS_TCTI=”swtpm:port=2321”

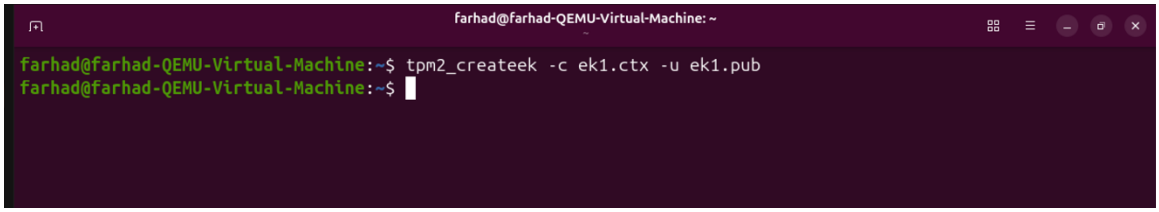
بررسی ارتباط شبیه‌ساز با ابزارها



عکس۵ – اجرای کامند tpm2_getrandom 4

تغییر کلید Endorsement و ایجاد AIK (بخش ۲.۲ تکلیف)

۱. استخراج EK فعلی

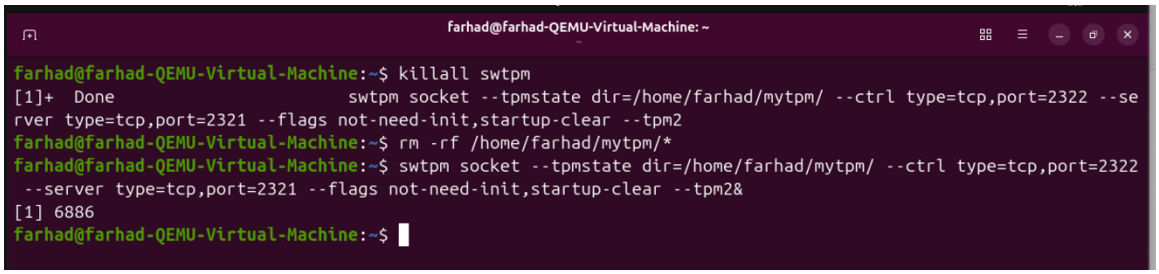


عکس۶ – اجرای کامند tpm2_createek -c ek1.ctx -u ek1.pub

فایل کانتکست کلید در ek1.ctx ذخیره می‌شود.

بخش عمومی کلید در ek1.pub ذخیره می‌شود.

۲. بازسازی وضعیت TPM



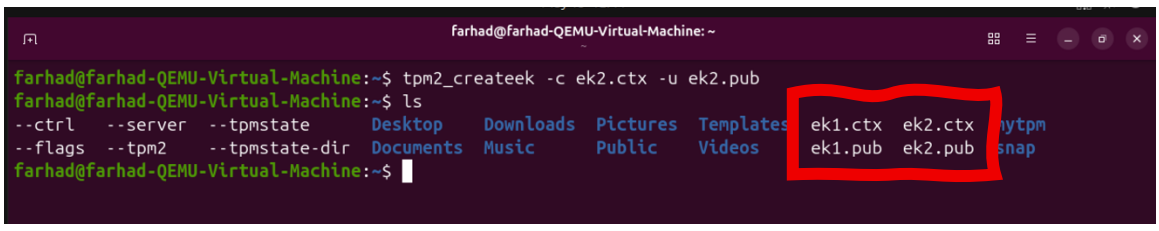
عکس۷ – اجرای کامندهای بازسازی وضعیت TPM

از کامند killall swtpm برا متوقف کردن پراسس مربوط به swtpm استفاده شده است.

از کامند rm -rf /tmp/mytpm برای پاک کردن وضعیت قبلی استفاده شده است.

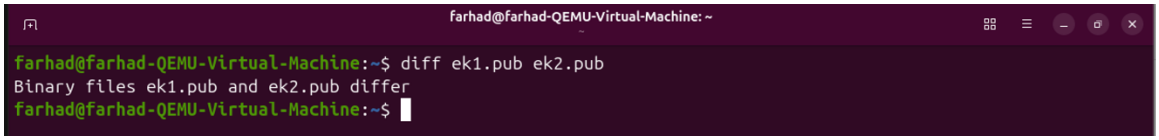
در کامند سوم مجددا شبیه‌ساز اجرا شده است.

۳. استخراج کلید عمومی Endorsement جدید



عکس۸ – اجرای کامند tpm2_createek -c ek2.ctx -u ek2.pub

۴. مقایسه دو کلید با دستور diff

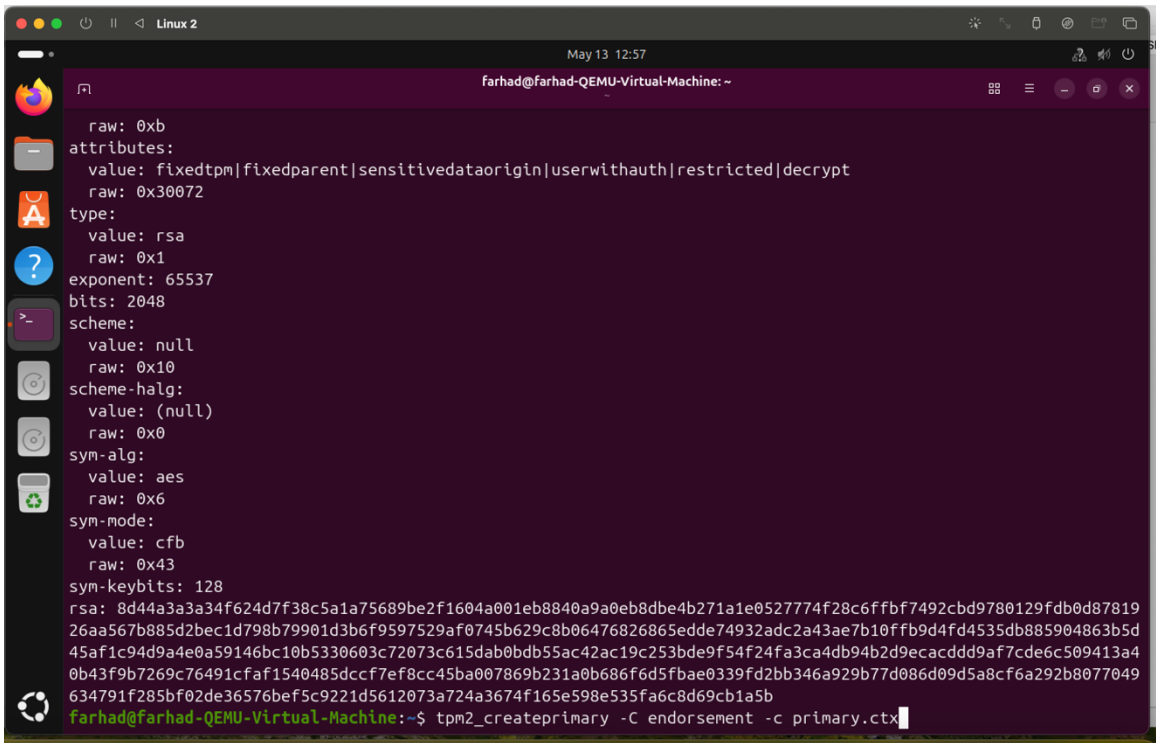


عکس۹ – اجرای کامند diff ek1.pub ek2.pub

خروجی نشان می‌دهد کلیدها متفاوت هستند.

۵. ساخت AIK و ماندگار کردن آن

۵. ۱. ایجاد کلید اصلی

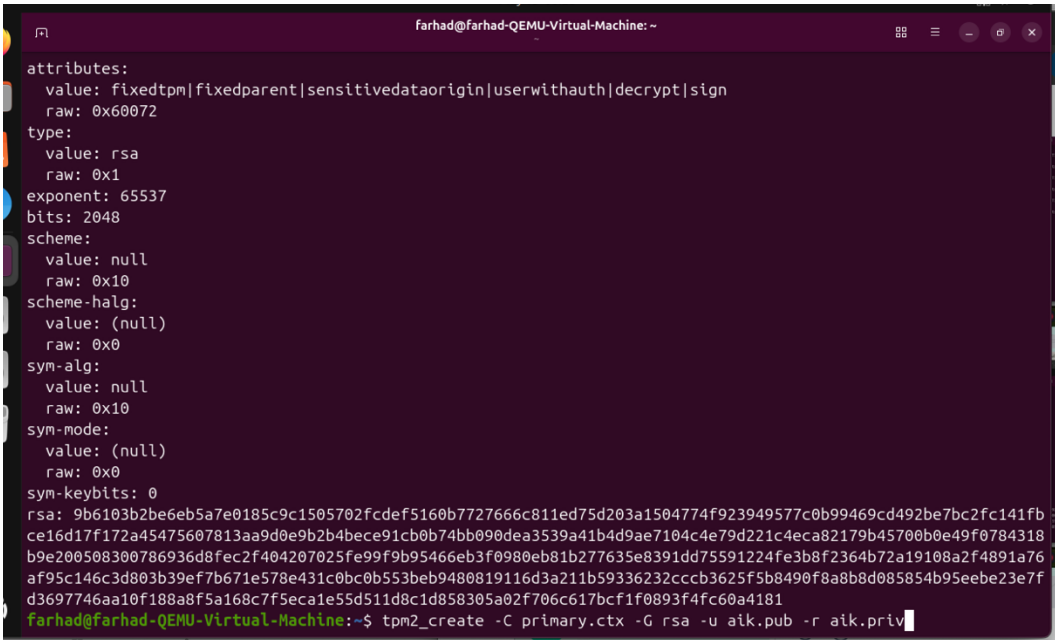


عکس۱۰ – اجرای کامند tpm2_createprimary -C endorsement -c primary.ctx

در این بخش سیستم یک جستجو برای یافتن سخت افزار انجام داد و که منجر به ارور شد، اما در ادامه به شبیه‌ساز متصل شد و کلید را با موفقیت ایجاد کرد. برای جلوگیری از ایجاد این ارور با دستور زیر از سیستم می‌خواهیم که مستقیما به شبیه‌ساز وصل شود و به دنبال سخت‌افزار نگردد.

export TPM2TOOLS_TCTI="swtpm:port=2321"

۵. ۲. ایجاد کلید اصلی



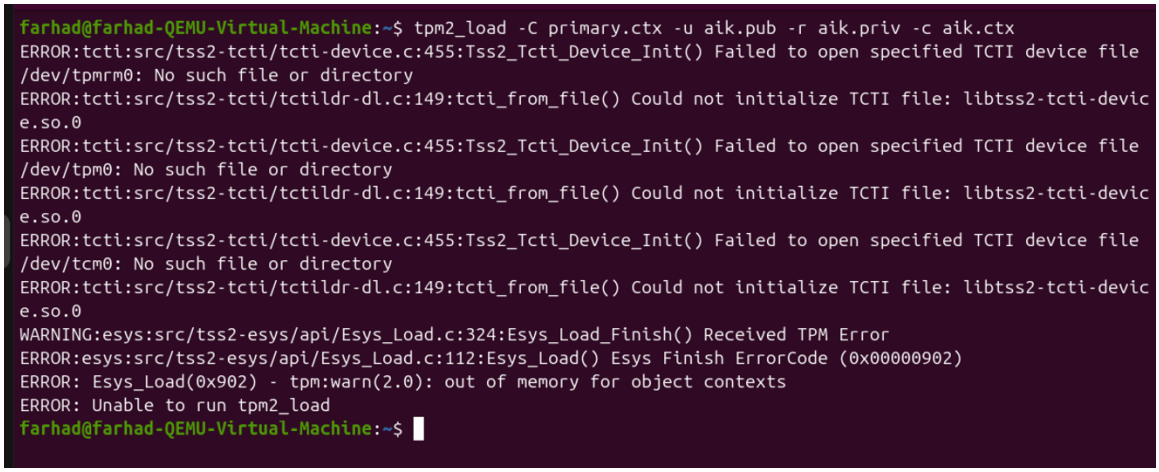
عکس۱۱ – اجرای کامند tpm2_create -C primary.ctx -G rsa -u aik.pub -r aik.priv

۵. ۳. بارگذاری AIK در TPM

اجرای اول این کامند منجر به خطای

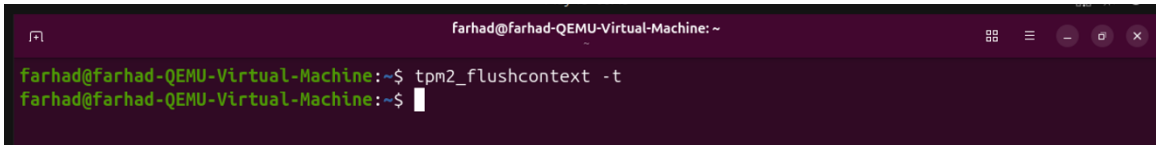
ERROR: Esys_Load(0x902) - tpm:warn(2.0): out of memory for object contexts

شد، دلیل این خطا پر شدن حافظه موقت شبیه‌ساز TPM است. (به دلیل ایجاد کلیدها و اشیاء مختلف در مراحل قبلی.



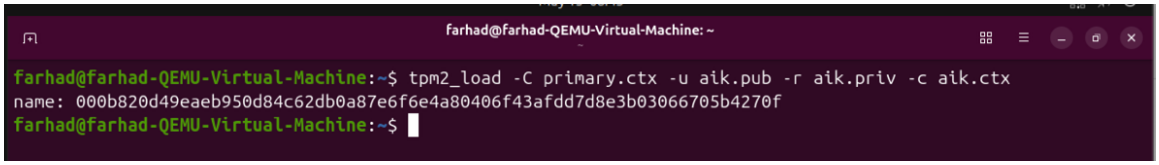
عکس۱۲ – اجرای کامند tpm2_load -C primary.ctx -u aik.pub -r aik.priv -c aik.ctx

خالی کردن حافظه موقت



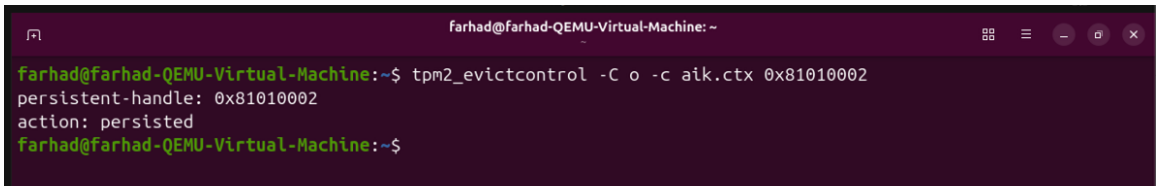
عکس۱۳ – اجرای کامند tpm2_flushcontext -t

بارگذاری مجدد AIK در TPM



عکس۱۴ – اجرای کامند tpm2_load -C primary.ctx -u aik.pub -r aik.priv -c aik.ctx

۵. ۴. ماندگار کردن کلید در TPM



عکس۱۵ – اجرای کامند tpm2_evictcontrol -C o -c aik.ctx 0x81010002

سوالات تئوری (بخش ۳ تمرین)

۱. فصل ۹ کتاب

چهار سلسله مراتب استاندارد:TPM 2.0

Platform Hierarchy: توسط فریم‌ور سیستم برای اندازه‌گیری بوت و مدیریت سطح پایین پلتفرم استفاده می‌شود.

(Storage Hierarchy (Owner: متعلق به سیستم‌عامل و کاربر هست که برای ایجاد و ذخیره کلیدهای رمزنگاری و محافظت از داده‌ها استفاده می‌شود.

Endorsement Hierarchy: مخصوص هویت و حریم خصوصی است و کلیدهای تضمینی سازنده ماژول در آن قرار دارند.

Null Hierarchy: برای ایجاد کلیدهای موقت استفاده می‌شود که با هر بار راه‌اندازی مجدد سیستم به طور کامل پاک می‌شوند.

افزایش امنیت نسبت به TPM 1.2، تو نسخه 1.2 تنها یک روت مالکیت وجود داشت که توانایی مدیریت همه چیز را داشت. در TPM 2.0، این سلسله‌مراتب‌ها کاملا مستقل هستند (تفکیک وظایف). به عنوان مثال، پاک کردن داده‌های Storage باعث از بین رفتن کلیدهای سازنده (Endorsement) یا دسترسی‌های فریم‌ور نمی‌شود. این استقلال هم امنیت و هم حریم خصوصی را افزایش می‌دهد.

۲. فصل ۱۲ کتاب

رجیسترهای PCR برای ثبت هش اندازه‌گیری‌های اجزای سیستم از لحظه روشن شدن تا اجرای سیستم‌عامل استفاده می‌شوند. در فرآیند Remote Attestation سیستم وضعیتPCR های خود را به همراه یک امضای دیجیتال برای سرور ارسال می‌کند تا ثابت کند نرم‌افزار و سخت‌افزار آن دستکاری نشده است.

عملیات Extend و مقاومت در برابر دستکاری، کسی نمی‌تواند مقدار دلخواهی را مستقیماً در PCR بنویسد. بلکه باید از عملیات Extend استفاده کند که بر اساس فرمول ریاضی

$PCR_{new} = Hash(PCR_{old}||data)$

کار می‌کند. چون توابع هش یک‌طرفه هستند و مقادیر جدید به مقادیر قبلی زنجیر می‌شوند، تغییر یا جعل تاریخچه اندازه‌گیری‌ها برای مهاجم غیرممکن است.

ارتباط با Sealing/Unsealing: در عملیات Sealing داده‌ها تنها زمانی بازگشایی می‌شوند که مقادیر فعلی PCR دقیقاً با مقادیری که در زمان Seal شدن ثبت شده‌اند برابر باشد. اگر بدافزاری در سیستم اجرا بشود مقدار PCR تغییر می‌کند و TPM اجازه دسترسی به داده‌ها را نخواهد داد.

۳. فصل ۱۳ کتاب

استاندارد TPM 2.0 از سه مکانیزم اصلی برای احراز هویت پشتیبانی می‌کند:

Passwords: کلمه‌عبورهای ساده که به صورت متنی ارسال می‌شوند.

HMAC Sessions: استفاده از رمزنگاری برای اثبات داشتن کلید بدون ارسال مستقیم آن که از حملات تکرار و شنود جلوگیری می‌کند.

Extended Authorization Policies: استفاده از سیاست‌های شرطی پیشرفته.

مزیت اصلی Policy نسبت به Password: استفاده از Policy به شما اجازه می‌دهد دسترسی را به مجموعه‌ای از شروط پیچیده و ریاضی وابسته کنید، مثلا در صورتی که PCRمقدار X را داشته باشد AND زمان خاصی باشد AND کاربر یک پین وارد کند.

ارتباط با آزمایش Sealing: در آزمایش عملی شما عملیات Sealing صرفاً با یک رمز عبور ساده انجام نمی‌شود بلکه یک Policy بر اساس وضعیت جاری PCRها ساخته شده و به شی متصل می‌شود. این یعنی حتی اگر یک مهاجم رمز عبور را داشته باشد یا کلید را کپی کند، به دلیل برقرار نبودن شرط Policy، TPM داده‌های Unseal شده را به او تحویل نخواهد داد.